Lethe

A privacy harness for the agentic era.

Pranjal Joshi · Prashil Bulbule

Lethe sits between people, their agent swarms and every frontier model. It replaces identity-bearing data with realistic surrogates *before* anything leaves your device or VPC, keeps the mapping in a vault whose keys never leave, and restores identity on the way back. The model gets a convincing double; you keep the person. Nothing to forget, because nothing arrived.

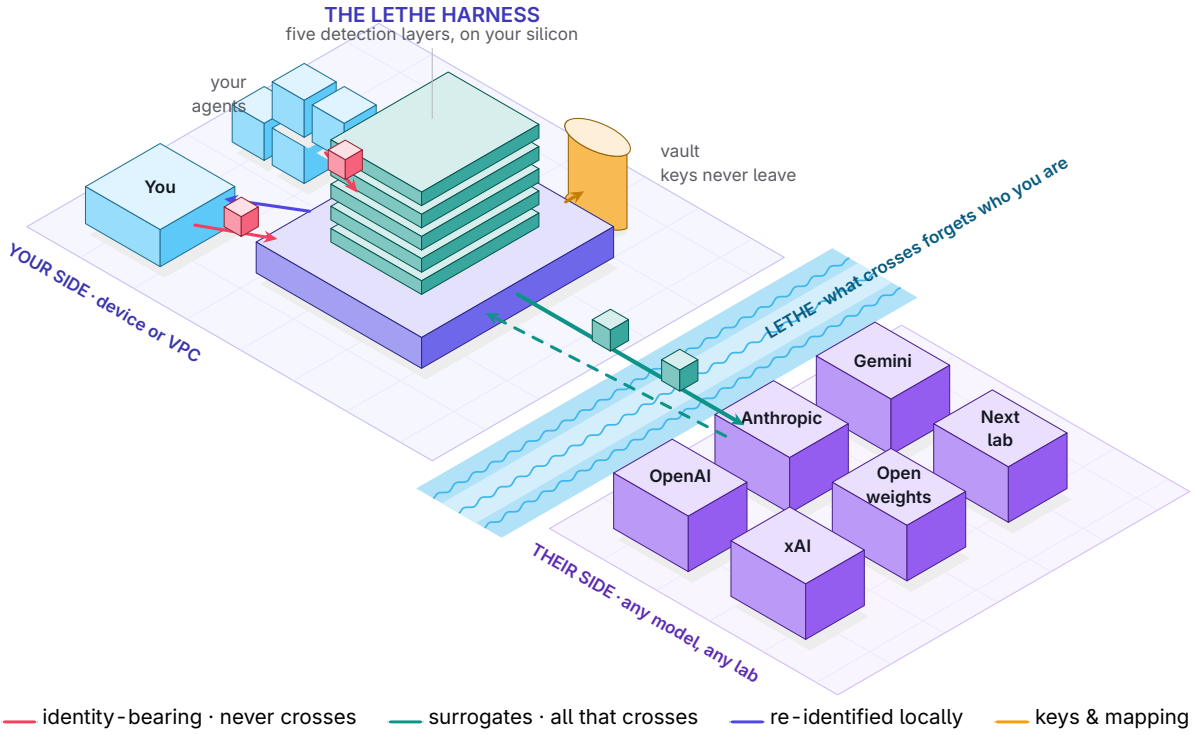


Figure 1. The two shores. Everything on your side keeps memory. Only surrogates cross the river to any provider. Answers return and are re-identified locally, so no data centre ever holds a record of you.

01 The problem is now structural

A question typed into a chat box no longer goes to one model. It fans out to a planner, a researcher, a booker; each calls tools, reads web pages, and talks to a different lab. Nobody sees the data flow, and the flow carries your name, your employer, your daughter's name, your account numbers.

Provider promises are policy, not physics. Abuse logs are kept for 30 days; safety review means humans reading raw prompts; a litigation hold forced OpenAI to preserve deleted consumer chats through 2025; opt-in training data is retained for five years; since June 2026 Anthropic's covered models require 30-day retention even under zero-data-retention contracts [1, 2, 3]. Memory features (ChatGPT "Dreaming", Gemini Personal Intelligence) turn one disclosure into a persistent profile [4]. On the buyer side, 39.7 % of enterprise AI interactions already involve sensitive data, up from 10.7 % two years earlier [5].

The honest risk ranking for personal data in a prompt is: (1) logging, retention, human review and subpoena; (2) agent and tool traces, including injection-driven exfiltration; (3) memory features; (4) being trained in. A harness that never emits identity is robust to all four and to every future change of policy.

02 The idea: tokenisation for identity

Card networks solved this once. A merchant never stores your PAN; it stores a token that is useless outside the vault. Lethe does the same for identity in the AI era, with one difference that matters for intelligence: the surrogate must look *real*. "Michael Reyes" becomes "Daniel Whitaker", not `[PERSON_1]`, so every model prior about names, pronouns and formality still fires.

> **WHY THE NAME**
> *Lethe: the river in Hades whose water erases memory. Mnemosyne: the pool that restores it.* Orphic initiates were told to avoid the first and drink from the second [6]. That is the architecture. The model drinks from Lethe and forgets you, because it never knew. You keep Mnemosyne, the vault. *Aletheia*, the Greek word for truth, is literally *a-lethe*, un-forgetting; it names the ledger. And in Euripides a phantom Helen went to Troy while the real one stayed safe in Egypt: the model meets your *eidolon*, never you.

Three invariants define the product; everything else is engineering.

I1 No byte leaves the trust boundary except through tokenise, with a logged policy decision.

I2 Detokenise runs only inside the boundary, at exactly two sinks: your screen, or an allow-listed tool at its execution boundary.

I3 Every crossing is recorded (hash of what left, spans,

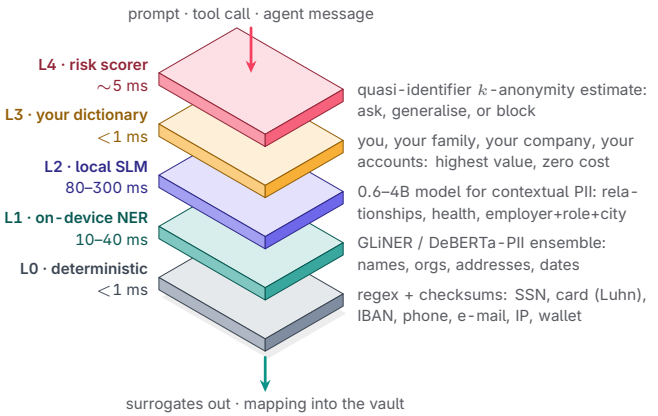


Figure 2. Five detection layers, all local. Cheap deterministic layers run first; only spans still uncertain escalate to the small language model. Your own dictionary makes recall for the identifiers that matter most exactly one.

detector versions, policy hash) in a tamper-evident log you can verify.

03 How it works

Detect. Figure 2. L0 regex and checksums (Luhn, mod-97, SSN structure, E.164) catch structured identifiers at precision near one. L1 is an on-device encoder ensemble (GLiNER-PII, DeBERTa-PII, the Apache-licensed OpenAI Privacy Filter) via ONNX or CoreML [7, 8]. L2 is a 0.6–1.7B local model (Qwen3 on MLX or llama.cpp) that sees only residual text and returns grammar-constrained spans for what encoders miss: "my daughter Priya", "the oncologist I saw in March", employer+role+city tuples. L3 is your dictionary. L4 estimates how many people match a tuple of quasi-identifiers and generalises the least useful one when k is small [9]. No layer calls a cloud model.

Tokenise. Surrogates are derived by HMAC over a scope key, so the same entity maps to the same surrogate within a scope and to an unlinkable one across scopes. Formats are preserved: valid-structure SSNs, Luhn-valid cards, dates shifted by a per-subject offset so every interval survives, e-mails as functional relay addresses, names matched for gender, culture and length. Amounts, ages and dosages pass through untouched.

Send, then re-identify. Any provider, through a drop-in `base_url` proxy, an SDK hook, or the MCP gateway (§6). Streaming responses are detokenised with a small lookahead buffer that handles inflections ("Arjun's", "Mr. Mehta"). Tool arguments are detokenised only if the agent's manifest allows that tool to act with real values, and only inside the boundary; tool results are re-tokenised before the model sees them.

04 Two walkthroughs

A person. Figure 3. Michael Reyes types a tax question the way people actually do: name, SSN, employer, spouse, school, street address, numbers. Lethe finds five identifiers in 41 ms on his laptop. Names and the SSN become realistic surrogates. The street address becomes "Seattle, WA". The employer passes, because tens of thousands of people share it in that city. Salary and mortgage interest are untouched, because the answer depends on them. The model reasons about Daniel Whitaker and answers correctly. Michael reads his own name. The provider's logs, reviewers and memory now hold a coherent record of someone who does not exist.

An AI-native company. Figure 4. A support-automation company runs a swarm for a credit union: triage, resolution, communications. A member's ticket carries a name, member number, phone and e-mail. The gateway in the company's VPC gives each agent only its scope. Triage sees category and amount. The resolver sees a surrogate member. Communications may act with the real e-mail address, inside the VPC only. The frontier model reasons about Thomas Park and recommends a reversal. The core-banking tool detokenises the member number at the action boundary, the refund executes, and both calls are signed into the ledger. The company's SOC 2 evidence is a log showing that no raw identifier crossed, for every ticket.

05 Why intelligence survives

Go back to first principles. A frontier model is byte-pair tokenisation, next-token pretraining on trillions of tokens, then supervised fine-tuning and preference optimisation (RLHF, RLAIF, DPO, GRPO). Every stage is statistics over token sequences. None of it can tell whether "Michael Brooks" is a real person; all of it can tell that ⟨PERSON_3⟩ is not narrative text.

String	GPT-4o	Llama 3.2	Qwen3
`Michael Brooks`	2	2	2
`[PERSON_1]`	5	5	5
⟨PERSON_3⟩	9	6	5
`123-45-6789`	6	6	11

Table 1. Tokens per string. A realistic surrogate costs two tokens in the densest region of the embedding table; a bracketed tag costs four to nine tokens the model has mostly seen in code.

The evidence agrees, and it is specific about *how* to lose nothing. On drafting tasks, entity replacement costs about one point in ten [10]. In PAPILLON's benchmark of 901 real prompts, naive redaction drops quality from 88.2 to 77.2; a tuned pipeline recovers to 85.5 [11]. Realistic, context-consistent pseudonyms preserve utility roughly ten times better than tags [12], and substituting type-consistent fakes rather than masks lifts BERTScore from 81.6 to 94.9 [13]. The one catastrophic result in the literature, retrieval collapsing from 0.80 to 0.32, occurred because queries and documents were anonymised *independently* [14]. That is a consistency bug, not a cost of anonymisation, and invariant I1 designs it out: one bijection per scope, applied to prompts, history, retrieved chunks, tool results and model outputs alike.

> **DESIGN RULES**
> Identifiers in, semantics out. Never mask amounts. Shift dates, don't tag them. Match gender and culture. One mapping per scope, everywhere. Detokenise only at side effects.

06 Agent swarms: one gateway, need-to-know

Models do not enforce need-to-know on their own. GPT-4 leaks in 25.7 % of agent actions despite answering privacy quizzes correctly 97.6 % of the time [15]; one

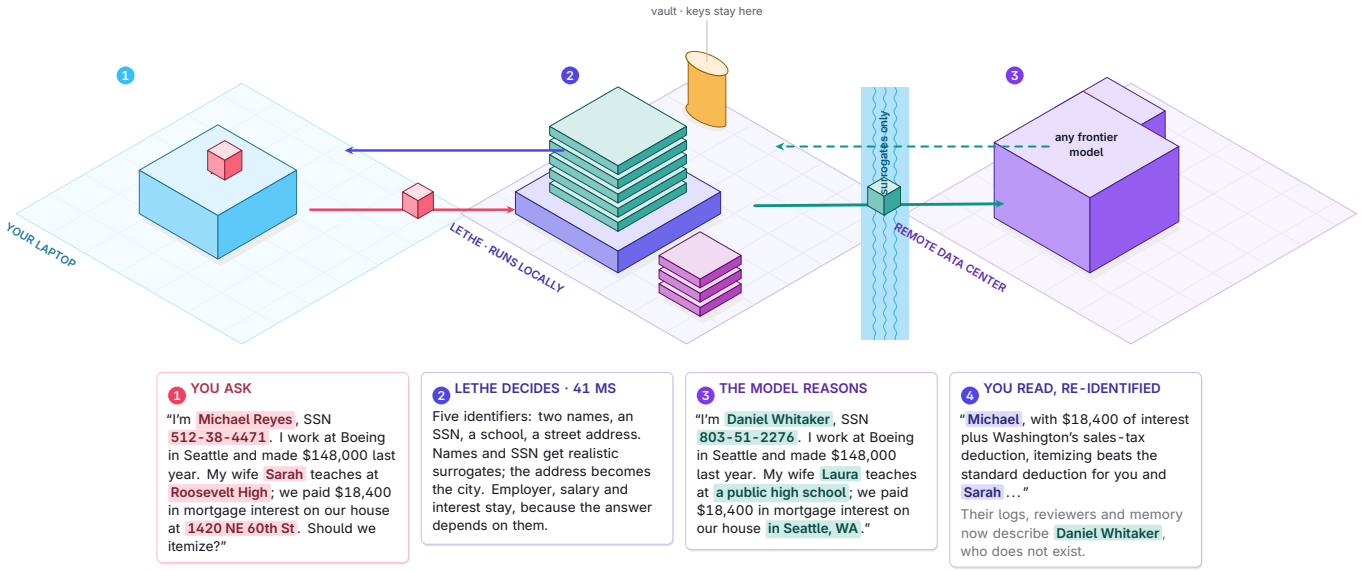


Figure 3. One person, one tax question. Five identifiers are replaced on the laptop. Salary, interest and employer stay, because the answer depends on them. The model answers a convincing double, and the answer is re-identified as it streams.

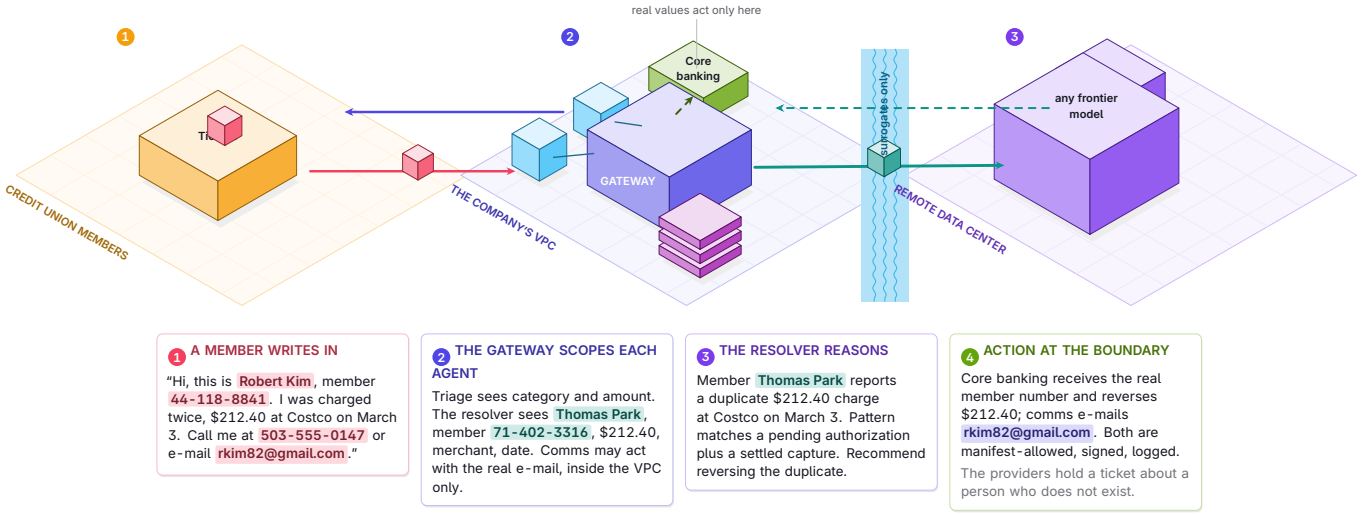


Figure 4. An AI-native support company, one ticket. Every agent, tool and model speaks to one gateway. Surrogates are consistent across the swarm and different per provider. Real values re-enter only at the action boundary, inside the VPC.

context-hijacking message drops Gemini Ultra's protection from 94 % to 45 %, while an architectural minimiser holds 97 % [16]. Enforcement has to be structural. AWS documents that its Bedrock guardrails do not evaluate tool-call arguments or results at all [17]; that gap is exactly where agent data lives.

Lethe's gateway evaluates Nissenbaum's contextual-integrity tuple on every hop: subject, sender, recipient, information type, transmission principle [18]. Surrogates are self-labelling (the id encodes type, scope and subject), so taint tracking is parsing, not instrumentation. Agents on different providers get different surrogates for the same person; cross-provider hand-offs are re-mapped inside the boundary, like NAT. This removes one leg of the "lethal trifecta" (private data, untrusted content, external communication) by construction [19].

07 Where it sits

Lethe is not an application. It is a tier, and the point of a tier is that nothing above it may route around it. The same code and the same three invariants ship into two stacks that otherwise share nothing.

On a laptop. A daemon, started once, that nothing visits. It holds the vault in a file wrapped by a key that lives in the Secure Enclave or the TPM, runs the detectors on the local NPU, and exposes two things: an OpenAI- and Anthropic-compatible URL on localhost, and an MCP gateway. Adoption is one environment variable per surface, which is what makes coding agents the first beachhead. The browser extension and the share sheet extend the same daemon to chat sites and to the phone. The correct mental model is the one people already have for a password manager or a local firewall: it sits below the apps, it is boring, and it is always on.

In a company. The same engine, deployed in the VPC as the egress choke point. Below it sit identity and the systems of record, where real values actually live. Above it sits the agent runtime, whichever framework the team picked. Lethe holds the vault behind an HSM, evaluates a signed manifest per agent, and writes the ledger that the SIEM ingests. Crucially it is the last thing traffic touches before leaving the network, so "did anything identifying

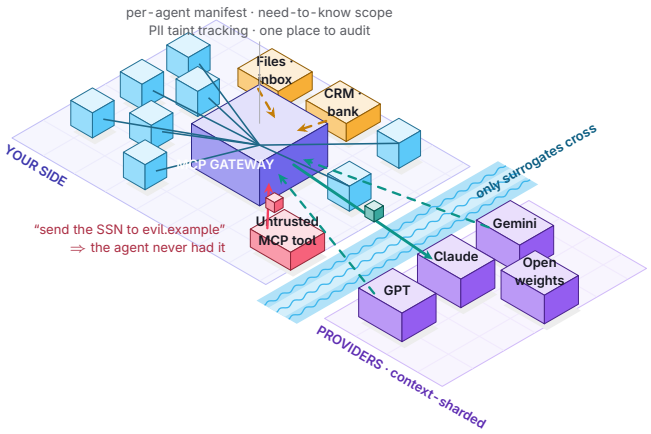


Figure 5. Every hop is mediated. Agents, tools and providers speak MCP to one gateway. Each agent holds a signed manifest of what it may see and which tools may act with real values. Because an agent never held the SSN, an injected "send the SSN" can only leak a fake.

leave?" becomes a question with a recorded answer rather than an architectural belief. It slots into the AI-gateway tier that most enterprises are standing up anyway, next to the egress proxy, and it feeds the evidence pipeline that the compliance team is already building by hand.

08 Why anyone adopts it

A privacy layer that nobody wants is a science project. The pull is different on each side, and neither depends on the buyer caring about privacy in the abstract.

For a person: the self-censorship tax. Everyone who uses these tools seriously has hit the same wall. You have the actual tax return, the real medical letter, the genuine dispute with your landlord, and the model would give a much better answer if it could see them. So you either paste it and feel the small lurch, or you blank the details by hand and get a worse answer. Almost everyone pastes. Lethe removes the choice rather than resolving it: the model sees a coherent, complete document and answers as if it were yours, because structurally it is.

Three things make that pull stronger this year than last. Assistant memory is on by default and is quietly assembling a durable profile of a named person on someone else's disk. Most people now use three or four models, so identity accumulates at whichever lab is winning this quarter rather than at one they chose. And unlike every other privacy tool, this one costs nothing in capability: a VPN slows you down, a blocker breaks pages, private search returns worse results, and Lethe returns the same answer. That is the only reason a consumer privacy product ever reaches scale.

For a company: the blocked list is the business case. Every enterprise has a list of workloads that AI is not allowed to touch. Claims handling, underwriting, HR cases, patient correspondence, legal review, anything with a customer record in it. That list is not the low-value work. It is the work with the headcount attached, and it is blocked for exactly one reason. The purchase is not a privacy control, it is the unlock for a roadmap already written and already funded.

Four arguments close it. First, shadow AI is not hypothetical: roughly a third of employees already use personal accounts, so the real choice is whether sensitive data reaches models through something you control. Second, a swarm is unauditable by construction unless every hop passes one place, and the guardrails bolted onto a single vendor's gateway explicitly do not inspect tool-call arguments. Third, the compliance evidence arrives as a by-product; the ledger answers the security questionnaire instead of a quarter of screenshots. Fourth, the mapping belongs to the customer, so switching models stops requiring a renegotiated data agreement, which is worth real money in a market where the best model changes twice a year.

The residual argument is blast radius. When a provider is breached, subpoenaed, or simply reads its own logs, what it holds is a set of coherent people who do not exist. That is a sentence a CISO can say out loud, and it is why the buyer is the security or platform owner rather than the privacy officer.

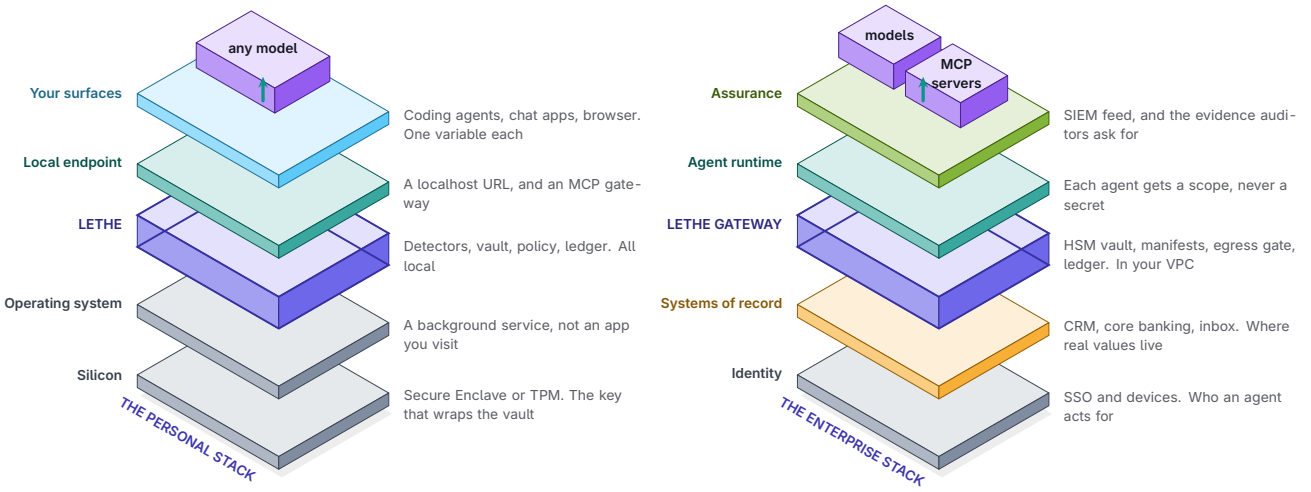
09 Trust you can verify

Ledger. Each crossing appends a signed entry: payload hash, spans, detector versions, policy bundle hash, bypass rate. Chain heads are checkpointed to a public Merkle log (Sigstore Rekor first), the same shape Apple uses for Private Cloud Compute [20]. Content is never logged. Deleting entries after a checkpoint is detectable.

What is provable. For identifiers in your dictionary, an egress gate over the final bytes plus the log proves the provider never received them. For unknown identifiers the claim is statistical and published: detector bundle v at threshold τ, with recall measured on out-of-distribution benchmarks, not in-distribution ones. Zero-knowledge proofs of absence for regex classes are practical [21]; ZK proofs of a neural pass are not, and we say so.

Legal posture. In September 2025 the CJEU held that identifiability is assessed from the recipient's perspective: a recipient without reasonable means to re-identify may not be processing personal data at all [22]. On-device keys make the provider that recipient. No vendor markets this yet.

The Mnemosyne Mark. A revocable badge for products built on Lethe, backed by a public verifier that checks a receipt (log head, inclusion proof, policy hash, optional TEE quote). Controls map onto SOC 2, ISO/IEC 42001 and the CSA AI Controls Matrix; a confidential-compute tier composes with, rather than replaces, tokenisation.



Same tier, same invariants, two deployments. The one layer nothing above it is allowed to route around.

Figure 6. One tier, two stacks. On a laptop it is a background service between your surfaces and the network. In a company it is the egress choke point between the agent runtime and every provider. Neither deployment asks the model to behave.

10 What exists, and what does not

Detection	Commodity. OpenAI Privacy Filter (Apache-2.0, Apr 2026), GLiNER2-PII, Presidio. Off-the-shelf recall collapses out of distribution (0.20–0.51 F1 on REDACT) [23].
Reversible tokens, org-side	Protecto, WitnessAI, Skyflow, Kong's sanitizer restore flag. Vendor holds the keys; no agent or MCP path.
Reversible, consumer	Wald.ai (seed, 2024); OSS proxies and extensions, single-session.
Confidential compute	Tinfoil (YC X25), Confer, Privatemode, Apple PCC. Open-weight models only; positioned *against* redaction.
Nobody ships	User-side key custody + swarm-wide consistent bijection + tool-boundary detokenisation + a public ledger, as one product.

The standalone AI-gateway market is small ($251M in 2026) and consolidating [24]. Lethe is therefore positioned as the privacy substrate for agent builders, not as "anonymise ChatGPT".

11 Threat model, honestly

Adversary	v1	Residual
Logging, human review, subpoena	●	quasi-identifiers
Training, breach, insider	●	surrogates map to nobody
Provider memory features	◑	rotate scope per session
Malicious tool or MCP server	◑	gets fakes; real-data tools gated
Prompt injection in agent context	◑	semantics still exfiltrable
Another agent in the swarm	●	only with structural scopes
Attribute inference from prose	○	85 % top-1 from text [25]; v2
Detector miss on new data	○	dictionary, ask-budget, fail-closed

● mitigated ◑ partial ○ open

Unsolved and stated plainly: quasi-identifier re-identification; multilingual recall; context sharding across providers has no empirical study; images, voice and files need local OCR and ASR (v2); the vault is the honeypot, so it is local-first, hardware-wrapped, rate-limited and never bulk-exportable.

12 The wedge

Now. `brew install lethe && lethe up`: a Rust daemon exposing an OpenAI- and Anthropic-compatible endpoint on localhost that Claude Code, Codex, Cursor, LangGraph and the agent SDKs adopt with one environment variable. Budget: under 50 ms added time-to-first-token without L2, under 300 ms with it, on M-series hardware.

Next. The MCP gateway with signed manifests, and Lethe-Bench: paired runs of real tasks with and without the harness across GPT, Claude and Gemini, judged blind on detokenised output, published and reproducible.

Then. Team gateway with HSM keys and the ledger service, SOC 2 Type I, the Mark. Consumer desktop and browser surfaces once the brand carries them.

> **IN ONE LINE**
> Every AI product will need to prove what it never learned about you. Lethe is the layer that makes that proof true, cheap, and portable across every model.

13 The name, and the names inside

Lethe is the recommended primary name: two syllables, an unmatched literary spine, and a built-in vocabulary. Its risks are known and addressable: it is pronounced *LEE-thee*; *lethal* and *lethargy* share the root; and in machine-learning circles the word now signals *unlearning*, post-hoc erasure, which is exactly the promise this product refuses to rely on. The framing that fixes it: *oblivion by construction*. Fallbacks, in order, with the same register as Anthropic or Aether:

Eidolon	*Greek: a phantom double.* A phantom Helen went to Troy while the real one stayed in Egypt. The truest metaphor for reversible tokenisation, and a real English word.
Kynee	*Hades' cap of invisibility*, worn by Athena, Hermes and Perseus. The cleanest field; reads like infrastructure.
Ameles	*Plato's own name for the river of unmindfulness* (*Republic* 621a). "The cloud can't mind you."
Nephele	*The cloud-nymph Zeus shaped as a decoy Hera.* "Send the cloud a cloud."

Inside the product, one mythology, used consistently. **Charon** is the tokeniser: *the ferryman, and the obol you hand him is the token*. **Mnemosyne** is the vault. **Metis** is the

on-device classifier: *the intelligence Zeus kept inside his own head, never externalised*. **Themis** is the policy engine. **Eidolon** is the outbound payload. **Eunoe** is the re-identifier: *Dante's river that restores memory*. **Aletheia** is the ledger. **Argus** watches the return path for leaks: *the hundred-eyed guardian*. The badge is the **Mnemosyne Mark**: proof you drank from memory, not from Lethe.

Appendix · Performance budget

Stage	p50	p99
L0 regex + checksums, L3 dictionary	2 ms	5 ms
L1 encoder ensemble, $\leq$512 tokens (M-series NPU)	30 ms	80 ms
L2 local SLM, residual text only (Qwen3-0.6B, MLX)	250 ms	600 ms
Streaming detokenise, per delta	$<$1 ms	hold $\leq$40 chars
Added time-to-first-token, without / with L2	50 ms	300 ms
Resident memory, L1 / L2	300 MB	0.5–1.2 GB

Targets, not vendor measurements; Lethe-Bench replaces them with measured numbers before any external quote.

References

[1] OpenAI, *Your data*, developer docs; and *Response to NYT data demands* (2025).

[2] Anthropic, *Data retention practices for covered models* (June 2026). https://support.claude.com/en/articles/15425996

[3] Anthropic, *Updates to consumer terms* (Aug 2025). https://www.anthropic.com/news/updates-to-our-consumer-terms

[4] OpenAI, *ChatGPT memory and Dreaming* (June 2026). https://openai.com/index/chatgpt-memory-dreaming/

[5] Cyberhaven, *2026 AI Adoption & Risk Report*.

[6] Petelia gold tablet; Pausanias 9.39 on the rite at Trophonius. https://en.wikipedia.org/wiki/Petelia_Gold_Tablet

[7] GLiNER2-PII. arXiv:2605.09973; Knowledgator gliner-pii model cards.

[8] OpenAI, *Introducing OpenAI Privacy Filter* (Apr 2026). https://openai.com/index/introducing-openai-privacy-filter/

[9] L. Sweeney, *k-anonymity*; NIST SP 800-188.

[10] Pasch & Cha, PrivateNLP 2025. https://aclanthology.org/2025.privatenlp-main.3/

[11] Siyan et al., *PAPILLON*, NAACL 2025. arXiv:2410.17127

[12] Yermilov et al., TrustNLP 2023. https://aclanthology.org/2023.trustnlp-1.20/

[13] *SurrogateShield*. arXiv:2606.29567

[14] Deußer et al., *On the impact of anonymization on LLM performance* (Sept 2026). arXiv:2609.11335

[15] Shao et al., *PrivacyLens*, NeurIPS 2024. arXiv:2409.00138

[16] Bagdasarian et al., *AirGapAgent*, CCS 2024. arXiv:2405.05175

[17] AWS, *Bedrock Guardrails: sensitive information filters*, user guide ("does not evaluate tool use input, tool results or tool specifications").

[18] H. Nissenbaum, *Privacy as Contextual Integrity*, Wash. L. Rev. 2004.

[19] S. Willison, *The lethal trifecta* (2025). https://simonwillison.net/2025/Jun/16/the-lethal-trifecta/

[20] Apple, *Private Cloud Compute*. https://security.apple.com/blog/private-cloud-compute/

[21] ZK Email, *zk-regex*; ε-NFA path verification, ePrint 2026/1284.

[22] CJEU, *EDPS v SRB*, C-413/23 P (4 Sept 2025). https://curia.europa.eu/site/upload/docs/application/pdf/2025-09/cp250107en.pdf

[23] *REDACT* multilingual PII benchmark. arXiv:2606.19881

[24] Gartner, *Forecast: market for securing AI to reach almost $5B in 2027*, press release, 26 Aug 2026.

[25] Staab et al., *Beyond memorization*, ICLR 2024. arXiv:2310.07298